

NETWORK INTRUSION DETECTION LAB

Penetration Testing & Traffic Analysis Report

Prepared by:

Nancy Okereke

Cybersecurity Analyst | GRC & SOC Focus

Date: May 2026

Classification: Confidential — Portfolio Use Only

Environment: Isolated VirtualBox Lab (Kali Linux + Metasploitable 2)

1. Executive Summary

This report documents a controlled penetration test conducted against a Metasploitable 2 target system within an isolated VirtualBox lab environment. The objective was to simulate a realistic network intrusion scenario, capture and analyze malicious traffic, and demonstrate both offensive and defensive security capabilities relevant to SOC analyst and GRC roles in the fintech sector.

Three critical vulnerabilities were successfully exploited, all resulting in full root-level (uid=0) access to the target system. Network traffic was captured throughout using Wireshark, and all findings are mapped to the MITRE ATT&CK framework.

Metric	Result
Target System	Metasploitable 2 (192.168.56.101)
Attacker System	Kali Linux 2026.1 (192.168.56.102)
Total Vulnerabilities Exploited	3 Critical
Highest Access Achieved	Root (uid=0)
Sensitive Data Accessed	Yes — /etc/shadow (password hashes)
Traffic Captured	Yes — Wireshark PCAP
Overall Risk Rating	CRITICAL

2. Scope & Methodology

2.1 Scope

This assessment was conducted in a fully isolated lab environment with no connection to production systems or the internet. The target was Metasploitable 2, a deliberately vulnerable Linux virtual machine designed for security training.

Component	Details
Target IP	192.168.56.101
Attacker IP	192.168.56.102
Network Type	VirtualBox Host-Only Network
Operating System (Target)	Linux 2.6.x (Metasploitable 2)
Operating System (Attacker)	Kali Linux 2026.1
Tools Used	Nmap, Metasploit Framework, Netcat, Wireshark

2.2 Methodology

The assessment followed a structured penetration testing methodology aligned with industry standards:

- Phase 1 — Reconnaissance: Active scanning with Nmap to identify open ports, services, and OS details
- Phase 2 — Exploitation: Targeted exploitation of identified vulnerabilities using Metasploit and Netcat
- Phase 3 — Post-Exploitation: Privilege verification, system enumeration, and sensitive data access
- Phase 4 — Traffic Analysis: Wireshark PCAP capture and analysis of all attack traffic
- Phase 5 — Reporting: Documentation of findings with MITRE ATT&CK mapping and remediation recommendations

3. Reconnaissance Findings

3.1 Nmap Scan Results

An aggressive Nmap scan (-sV -O -A) was conducted against the target, completing in 153.66 seconds. The scan revealed 23 open TCP ports exposing a critically vulnerable attack surface.

Port	Service	Version	Risk Level
21/tcp	FTP	vsftpd 2.3.4	CRITICAL
22/tcp	SSH	OpenSSH 4.7p1	Medium
23/tcp	Telnet	Linux telnetd	High
25/tcp	SMTP	Postfix smtpd	Medium
80/tcp	HTTP	Apache 2.2.8	High
139/445/tcp	SMB/Samba	Samba 3.0.20-Debian	CRITICAL
1524/tcp	Bindshell	Metasploitable root shell	CRITICAL
3306/tcp	MySQL	5.0.51a-3ubuntu5	High
5432/tcp	PostgreSQL	8.3.0 - 8.3.7	Medium
5900/tcp	VNC	Protocol 3.3	High
6667/tcp	IRC	UnrealIRCd	CRITICAL
8180/tcp	HTTP	Apache Tomcat 5.5	High

3.2 MITRE ATT&CK Mapping — Reconnaissance

Technique ID	Technique Name	Tool Used	Description
T1595.001	Active Scanning: Scanning IP Blocks	Nmap	Port and service enumeration
T1592	Gather Victim Host Information	Nmap -O	OS fingerprinting (Linux 2.6.x)
T1590.005	Gather Victim Network Information	Nmap	Network topology mapping

4. Exploitation Findings

4.1 Exploit 1: vsftpd 2.3.4 Backdoor (CVE-2011-2523)

Severity: CRITICAL

Field	Details
CVE	CVE-2011-2523
Port	21/tcp (FTP)
Metasploit Module	exploit/unix/ftp/vsftpd_234_backdoor
Payload	cmd/unix/reverse_netcat
Access Achieved	Root shell (uid=0)
MITRE ATT&CK	T1190 — Exploit Public-Facing Application

Description: vsftpd version 2.3.4 contained a malicious backdoor intentionally inserted into the source code. When a username containing a smiley face ":" is sent to the FTP service, a backdoor shell is spawned on port 6200, granting unauthenticated root access. This is one of the most well-known supply chain compromises in open source history.

Result: Full root access obtained. Confirmed with whoami → root, uid=0(root) gid=0(root).

4.2 Exploit 2: Samba Username Map Script (CVE-2007-2447)

Severity: CRITICAL

Field	Details
CVE	CVE-2007-2447
Port	445/tcp (SMB/Samba)
Metasploit Module	exploit/multi/samba/usermap_script
Payload	cmd/unix/reverse_netcat
Access Achieved	Root shell (uid=0)
MITRE ATT&CK	T1190 — Exploit Public-Facing Application

Description: Samba versions 3.0.0 through 3.0.25rc3 contain a vulnerability in the username map script configuration option. When a username containing shell metacharacters is passed, arbitrary commands are executed with root privileges. This vulnerability requires no authentication.

Result: Full root access obtained. Command shell session 2 opened. Confirmed with whoami → root, uid=0(root) gid=0(root), hostname → metasploitable. /etc/shadow file successfully accessed, exposing password hashes for all system accounts.

4.3 Exploit 3: Bindshell Direct Root Access (Port 1524)

Severity: CRITICAL

Field	Details
CVE	N/A — Intentional misconfiguration
Port	1524/tcp (Bindshell)
Tool Used	Netcat (nc)
Command	nc 192.168.56.101 1524
Access Achieved	Direct root shell (uid=0)
MITRE ATT&CK	T1133 — External Remote Services

Description: Port 1524 on Metasploitable 2 runs a root bindshell — a shell bound directly to the port requiring no authentication. A simple Netcat connection immediately provides a root command prompt, demonstrating the extreme risk of exposed bindshells on any network-accessible service.

Result: Direct root access with no exploitation required. Confirmed with whoami → root, uid=0(root) gid=0(root) groups=0(root), hostname → metasploitable.

5. Network Traffic Analysis

5.1 Wireshark Capture Overview

All attack phases were captured using Wireshark on interface eth0 of the Kali Linux attacker machine. Two PCAP files were generated: `nmap_recon_capture.pcapng` (reconnaissance phase) and `exploitation_capture.pcapng` (exploitation phase).

5.2 Key Traffic Indicators Observed

Traffic Type	Protocol	IOC Description	Phase
Nmap SYN scan	TCP	Rapid sequential SYN packets to 1000+ ports from single source	Reconnaissance
FTP Banner Grab	FTP	FTP response code 220 revealing vsftpd 2.3.4 version	Reconnaissance
SMB Negotiation	SMB	SMB protocol negotiation revealing Samba 3.0.20 version	Reconnaissance
Reverse TCP Shell	TCP	Outbound connection from 192.168.56.101 to 192.168.56.102:4444	Exploitation
Bindshell Connection	TCP	Inbound TCP connection to port 1524 with immediate shell response	Exploitation
DHCP Traffic	DHCP	DHCP request/ACK confirming attacker IP assignment	Background
ARP Traffic	ARP	ARP who-has queries between both hosts confirming network topology	Background

5.3 Indicators of Compromise (IOCs)

- Source IP conducting port scans: 192.168.56.102
- Destination IP: 192.168.56.101
- Unusual outbound connection from target on port 4444 (reverse shell)
- Inbound connection to port 1524 (bindshell — should never be accessible)
- FTP traffic on port 21 followed immediately by TCP RST packets (backdoor trigger)
- SMB traffic on port 445 with command injection pattern in username field

6. MITRE ATT&CK Full Mapping

Tactic	Technique ID	Technique Name	Tool/Method
Reconnaissance	T1595.001	Active Scanning: Scanning IP Blocks	Nmap -sV -O -A
Reconnaissance	T1592	Gather Victim Host Information	Nmap OS detection
Initial Access	T1190	Exploit Public-Facing Application	vsftpd 2.3.4 backdoor
Initial Access	T1190	Exploit Public-Facing Application	Samba usermap_script
Initial Access	T1133	External Remote Services	Bindshell port 1524
Execution	T1059.004	Command and Scripting: Unix Shell	Reverse netcat shell
Discovery	T1082	System Information Discovery	uname -a, hostname
Discovery	T1087.001	Account Discovery: Local Account	cat /etc/passwd
Credential Access	T1003.008	OS Credential Dumping: /etc/passwd and /etc/shadow	cat /etc/shadow
Persistence	T1098	Account Manipulation	Root access enables account creation
Command & Control	T1095	Non-Application Layer Protocol	Raw TCP reverse shell on port 4444

7. Risk Summary

Vulnerability	CVE	CVSS Score	Risk	Impact
vsftpd 2.3.4 Backdoor	CVE-2011-2523	10.0	CRITICAL	Unauthenticated root RCE
Samba Username Map Script	CVE-2007-2447	10.0	CRITICAL	Unauthenticated root RCE
Exposed Bindshell Port 1524	N/A	10.0	CRITICAL	Direct root shell, no exploit needed
Anonymous FTP Login	N/A	6.4	HIGH	Unauthenticated file access
Telnet Service Exposed	N/A	7.5	HIGH	Plaintext credential transmission
MySQL No Authentication	N/A	7.5	HIGH	Unauthenticated database access
VNC Exposed	N/A	7.8	HIGH	Remote desktop access

8. Remediation Recommendations

8.1 Immediate Actions (Critical Priority)

- Upgrade vsftpd immediately — version 2.3.4 contains a known backdoor; patch to latest stable release
- Upgrade Samba — version 3.0.20 is critically vulnerable; update to 4.x and apply all security patches
- Remove or firewall port 1524 — bindshells should never be accessible; block at network and host firewall level
- Disable anonymous FTP — remove anonymous login capability or disable FTP entirely in favor of SFTP
- Disable Telnet — replace with SSH for all remote management; Telnet transmits credentials in plaintext

8.2 Short-Term Actions (High Priority)

- Implement network segmentation — restrict lateral movement between network zones
- Deploy an IDS/IPS — implement Snort or Suricata with rules to detect reverse shells and port scan patterns
- Enable MySQL authentication — configure strong passwords and restrict remote access
- Restrict VNC access — require strong authentication or remove if not needed
- Audit all exposed services — disable any service not required for business operations

8.3 Long-Term Actions (Strategic)

- Implement a vulnerability management program — conduct regular scans using tools like Nessus or OpenVAS
- Deploy a SIEM solution — centralize log collection and implement detection rules for IOCs identified in this report
- Establish patch management policy — define SLAs for critical patch deployment (e.g., 24-48 hours for CVSS 10.0)
- Conduct regular penetration testing — schedule quarterly assessments to identify new vulnerabilities
- Implement the principle of least privilege — ensure services run with minimal required permissions

9. Detection Rules & SOC Recommendations

9.1 Key Detection Signatures

The following detection logic should be implemented in a SIEM or IDS to identify the attack patterns demonstrated in this assessment:

Attack	Detection Logic	Alert Severity
Nmap Port Scan	SYN packets to >100 ports from single IP within 60 seconds	Medium
vsftpd Backdoor Trigger	FTP username containing ':' characters	Critical
Reverse Shell	Outbound TCP connection from server to client on non-standard port (e.g. 4444)	Critical
Bindshell Access	Inbound TCP connection to port 1524	Critical
Samba Exploit	SMB username field containing shell metacharacters (;, , \$)	Critical
/etc/shadow Access	File read events on /etc/shadow from non-root process	Critical

9.2 Recommended SIEM Queries (Splunk)

The following Splunk SPL queries can be used to hunt for similar activity:

Detect port scanning:

```
index=network sourcetype=firewall | stats count by src_ip dest_port | where count > 100 | stats count by src_ip
```

Detect reverse shell connections:

```
index=network dest_port=4444 OR dest_port=6200 | table _time src_ip dest_ip dest_port
```

Detect /etc/shadow access:

```
index=linux_logs file_path="/etc/shadow" | table _time user process file_path
```

10. Conclusion

This lab assessment successfully demonstrated a complete attack chain against a vulnerable Linux target, from initial reconnaissance through to full system compromise and sensitive data exfiltration. Three critical vulnerabilities were exploited, all resulting in root-level access, and all attack traffic was captured and analyzed using Wireshark.

The findings highlight the critical importance of patch management, network segmentation, and continuous monitoring. In a real-world fintech environment, any one of these vulnerabilities could result in a catastrophic data breach affecting customer financial data and regulatory compliance obligations under frameworks such as NDPC, PCI-DSS, and ISO 27001.

From a SOC analyst perspective, the traffic patterns and IOCs identified in this report provide practical detection logic that can be implemented in a SIEM environment to identify similar attacks in production. The MITRE ATT&CK mapping enables threat intelligence teams to correlate findings with known threat actor TTPs and prioritize defensive investments accordingly.

Assessment Area	Status
Reconnaissance	Completed — 23 open ports identified
Exploitation — vsftpd 2.3.4	Completed — Root access achieved
Exploitation — Samba 3.0.20	Completed — Root access achieved
Exploitation — Bindshell 1524	Completed — Root access achieved
Traffic Capture	Completed — PCAP files saved
MITRE ATT&CK Mapping	Completed — 11 techniques mapped
Remediation Recommendations	Completed